

INPUT

개인정보보호 X AI

N²SF 전환과 개인정보 공공기관 AI 도입을 위한 실전 체크리스트

DATA



PII



BIOMETRICS



LOCATION

KAPIE

한국정보공학기술사

© 2025. 이자원 기술사 All rights reserved

CTO/MINAL

AI

LEAK
PATHS

STORE



UNKNOWN
SERVERS

TRAIN



DPA

NO-STORE



OP-OUT



OPT-OUT



국가기술자격취득 응시자격 기준(기능사 → 산업기사 → 기사 → 기능장 → **기술사**)

한국정보공학기술사회는 정보처리 및 통신 분야 ICT 기술사를 중심으로 1995년도에 설립하여, 정보관리, 컴퓨터시스템응용, 정보통신, 전자응용기술사 등 2,000여명의 전문가가 활동하고 있는 **현장 중심 전문 기관**입니다.

설립근거 및 구성

- **설립근거 : 법률 제18425호, 「기술사법」 제14조**
 - 제1항 기술사는 그 직무의 개선, 기술능력의 향상 및 품위의 보전을 도모하기 위하여 과학기술정보통신 부장관의 인가를 받아 기술사회를 설립할 수 있다.
- **기술사 직무 : 「기술사법」 제3조**
 - 제1항 기술사는 과학기술에 관한 전문적 응용능력이 필요한 사항에 대하여 계획, 연구, 설계, 분석, 조사, 시험, 시공, 감리, 평가, 진단, 시험운전, 사업관리, 기술 판단(기술감정을 포함한다), 기술 중재 또는 이에 관한 기술자문과 기술 지도를 그 직무로 한다.
- **본회 구성 : 정보통신기술 관련 기술사 및 단체회원/특별회원 (2,000여명)**

가치 창출

정보통신 관련 제반 서비스
및 컨설팅 사업

사회 기여

국가 정보통신 정책 개발 및
제도개선, 기술자문

평생 교육

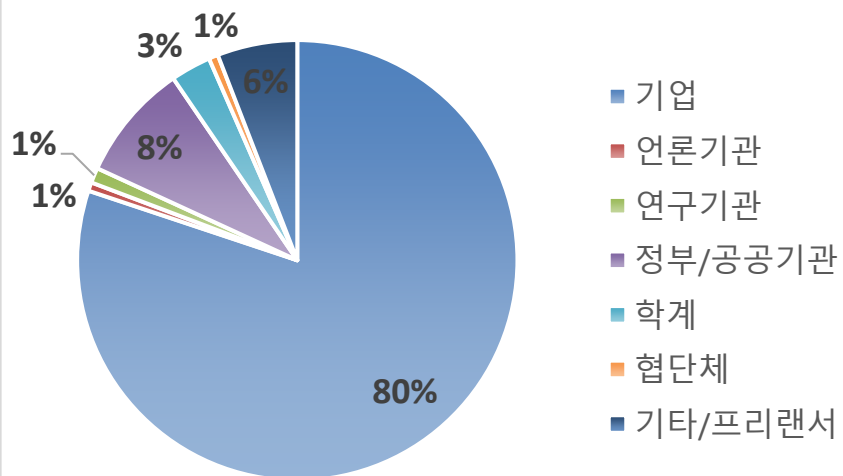
상호정보교환,
기술지도 및 사회봉사활동

역량 강화

정보통신 관련
연구개발(R&D)사업

KAPIE 기술사 재직 회사

소속 기관별 기술사 분포





한국정보공학기술사회 미래융합기술원

업무 영역

- 1 보안 및 인공지능 등 각종 기술에 대한 연구 및 외부 기고
- 2 혁신기술분야 발굴 및 기술평가
- 3 각종 기술 세미나 발표 지원 및 기술 교류



[한국정보공학기술사 보안을論하다-11] 인공지능 시대, 보안담당자의 역할

발행: 2025-03-17 17:30

본문 뉴스 게재됨

영상향 SoC의 모든 것!

보안담당자, AI 도입·활용 안전하게 관리하는 정보보안 거버넌스 역할 수행해야

[보안뉴스= 문광석 기술사/코리안리 IT보안파트장] 2016년 3월, 알파고(AlphaGo)와 이세돌의 바둑 대결에서 아무도 예상하지 못한 결과가 나왔다. 알파고가 4승 1패로 승리를 거두며, 본격적인 인공지능 시대의 서막을 알린 것이다.

사람들은 인공지능의 압도적인 실력에 놀라움을 감추지 못했고, 이후 알파고 마스터(AlphaGo Master), 그리고 학습 데이터 없이 스스로를 이길 수 있는 알파고 제로(AlphaGo Zero)까지 등장하며 인공지능 기술은 끊임없이 발전해 나갔다. 그 이후, 한동안 바둑이나 체스처럼 정해진 규칙 내에서 계산 능력이 뛰어난 ‘약한 인공지능’으로만 활용하며 사람들의 자신의 역할이 있음에 안심할 수 있었다.

보안 뉴스 게재됨

가장 친근하지만 꺼려로운

얼굴·홍채인식!

현재와 앞으로의 미래,

공급하면 Click Now!

제14회 개인정보보호페어 & CPO워킹숍
PISFAIR 2025 2025년 3월 27일(수) - 28일(목)
서울 삼성동 코엑스 그랜드컨벤션홀

제19회 국제 사육리터 콘퍼런스
ISEC 2025 2025년 3월 28일(목) - 29일(금)
서울 강서구 신정동 신정로15길 15 (신정역 5번 출구)

제25회 세계 보안 엑스포
SECON 2026 2026년 3월 18일(수) - 20일(금)
부산 한스 레저리조트 2-1동

제14회 전자정부 정보보호 솔루션 페어
eGISEC 2026 2026년 3월 18일(수) - 20일(금)
부산 한스 레저리조트 2-1동



문광석 한국정보공학기술사회 미래융합기술원장은 “KISA 공지에서 SKT를 언급하진 않았지만, BRF도 어 관련 내용을 다뤘다는 점에서 해당 사건 관련 내용으로 보인다”며 “업계에선 내부 백도어에 대한 백신과 엔드포인트 탐지 및 대응(EDR), 확장 탐지 및 대응(XDR) 등을 활용해 전수검사를 진행할 것을 권고하고 있다”고 말했다.

[조재호 기자(sw@boannews.com)]



인공지능(AI)기초본 이야기

KCI 등록
OSINT와 기업 내 사이버 위협 위험관리전략을 통한 효과적 위험 대응 기법
Effective Risk Management Technique through OSINT and Cyber Threat Intelligence within the Enterprise

정보보호학회논문지
약어: JKISCS
2024, vol.34, no.5, pp.949-959 (11 pages)
DOI: 10.13089/JKISCS.2024.34.5.949
발행기관: 한국정보보호학회
연구분야: 공학 > 컴퓨터학

문광석 [Kwangseok Moon¹], 허준범 [Junbeom Hur²]

우리나라가 글로벌 인공지능 국가 역량을 세계 6위를 차지 했다는 보도를 접하였다. 영국 언론 기관인 토러스미디어가 2025년 글로벌 인공지능 인덱스'에서 전 세계 83개국의 인공지능 경쟁력 수준을 비교 분석한 결과, 대한민국이 작년과 동일하게 종합 6위를 차지했다. 순위를 살펴보면 1위는 미국, 2위는 중국, 3위는 싱가포르, 4위는 영국, 5위는 프랑스이며, 7위로 8위는 각각 독일과 캐나다가 차지했다. 토러스미디어는 실험, 혁신, 투자라는 3가지 기준을 인제, 인프라, 운영환경, 연구, 개발, 정부정책, 생태계라는 7가지 영역을 평가한다. 이번 결과에서 프랑스는 '인프라'와 '인공지능'을 중심으로 '소버린 인공지능' 등을 육성하여 국가 차원의 지원 정책을 통해 13위에서 5위로 7단계 상승했다. 우리나라는 인공지능을 활용한 산업군별로 차이는 있으나, 선두권인 미국, 중국과의 기술 격차가 약 2-3년 정도로 평가된다. 문체는 인공지능 기술의 변화 속도를 고려할 때 2-3년의 격차가 매우 크다는 것이다. 대한민국은 이러한 기술 격차 극복을 위해 노력하는 가운데, 수년간 난항을 겪던 '인공지능 기본법'이 지난해 말에 국회에서 통과되었고, 내년 1월 본격 시행될 예정이다. 인공지능 발전과 신뢰 기반 조성 등에 관한 '기본법'의 출현이 인공지능 기본법으로 대한민국 인공지능 산업의 전환을 발판으로 지원하고, 사회의 신뢰 기반 조성에 필요한 기반 마련을 규정한다. 이 법은 인공지능 글로벌 3대 강국 도약과 오남용에 대한 규제 사이의 균형을 추구하는 법안으로 평가받고 있다. 이 기본법이 공포·시행되면 대한민국은 EU에 이어 두 번째로 인공지능 관련 입법법을 보유한 국가(또는 지역)가 된다.

본고에서는 기본법의 주요사항과 관련 논쟁에 대해 논하기에 앞서 인공지능의 의미부터 살펴보고자 한다. 인공지능의 정의와 발전 역사, 영역에 등장한 인공지능 모습을 살펴본다. 그리고 기본법의 토대가 된 법안들을 검토하고 해외 정책 및 법 제도와 비교해 본다. 마지막으로 인공지능을 둘러싼 글로벌 패권 경쟁 속에서 발전과 인간의 균형을 위한 기본법의 실효성 있는 정책 추진을 위해 보완의 필요성을 제언하고자 한다.

발표자 소개

한국정보공학기술사회 / 2025년 8월

- 이름 : 이제원 기술사
- E-mail : bwmslove@naver.com
- 소속 : 한국정보공학기술사회 / 차세대수치예보모델개발사업단
- 자격 : 정보관리기술사 / 컴퓨터시스템응용기술사
- 활동 : 미래융합기술원 보안 및 인공지능 분야 연구위원
- 보안뉴스 / 주간기술동향 기고

Content

한국정보공학기술사회 / 2025년 8월

1. N²SF와 개인정보보호

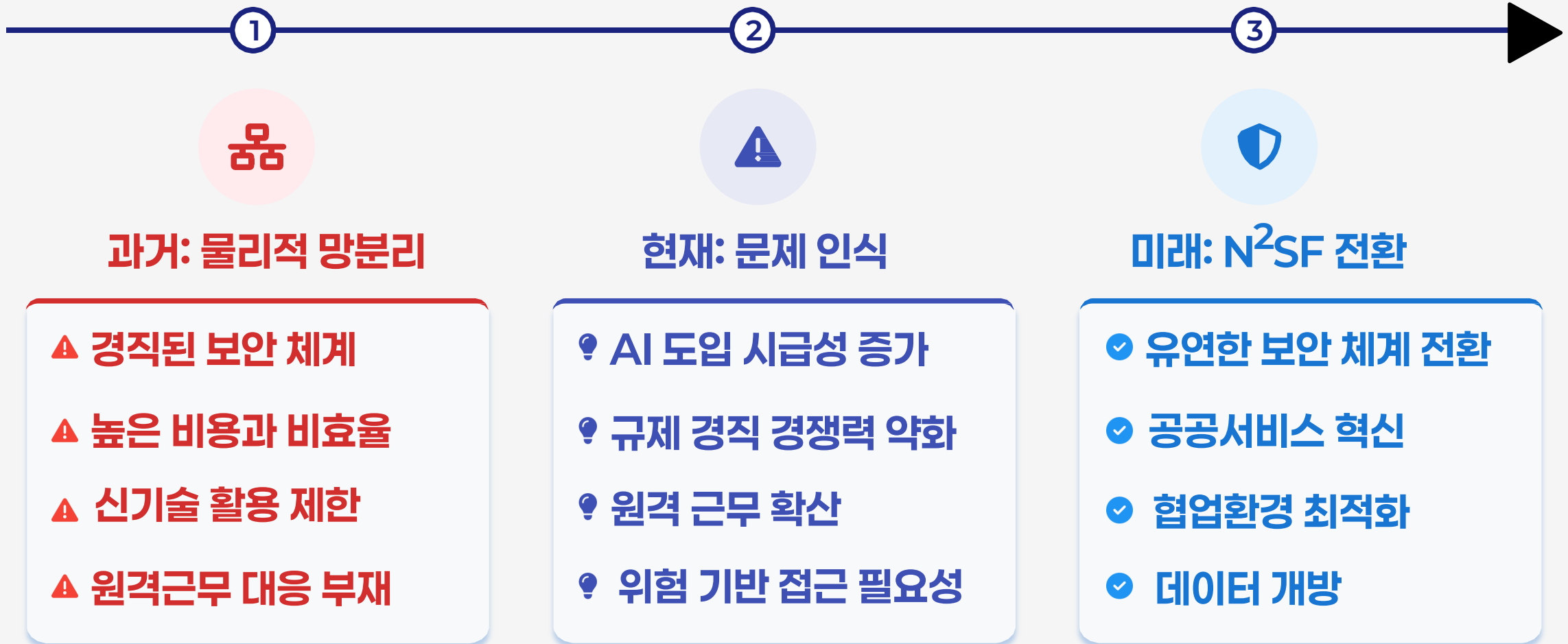
2. 개인정보 생애주기별 점검사항

3. AI 구축 유형별 점검사항

4. 공공기관 AI 도입을 위한 실전 체크리스트

N²SF 개요

과거 망분리에서 보안에서 N²SF로의 전환 과정



N²SF: 기존과 달라진 보안 체계

기존 물리적 망분리 체계

- ⚠ 모든 데이터에 동일한 보안 적용
 - 차등화된 보안 부재
- ⚠ 물리적 망분리
 - 내·외부망 분리에만 집중
- ⚠ 경직된 보안 체계
 - 클라우드, AI 등 신기술 도입 제약
- ⚠ 비효율적 업무 환경
 - 외부 협업 및 원격근무 지원 어려움

VS

N²SF Zero Trust 기반 모델

- ✓ 데이터 중요도별 차등 적용
 - C/S/O 등급별 맞춤형 통제
- ✓ 다계층 접근 통제
 - 인증, 권한관리, 로깅, 격리 등 복합 보안
- ✓ 유연한 보안 적용
 - 위험분석 기반 선별적 인터넷 접속 허용
- ✓ Zero Trust 원칙
 - "신뢰하지 않고 항상 검증"

N²SF의 C/S/O 등급 분류

국가 망 보안 체계 등급 분류

C (기밀, Confidential)

국가·기관 기밀, 공개 시 중대한 피해가 예상되는 정보

S (민감, Sensitive)

비공개 대상 정보 전반(개인정보 포함), 업무상 민감 정보

O (공개, Open)

공개 가능한 정보(공공데이터, 공자·보도자료 등)



자산 식별



위험/피해 평가



C/S/O 결정



등급별 통제 매핑

- **원칙** : 개인정보·비공개 정보는 최소 S에서 시작
- **차등화된 보호조치** : 각 등급별로 접근통제, 암호화, 로깅, 네트워크 분리 등 보호조치 수준이 다르게 적용
- **업무망 구분** : 물리적 망분리에서 등급별 논리적 보호조치 체계로 전환
- **위험 기반 접근** : 일률적 망분리에서 정보/업무 특성별 위험평가 기반 보호체계로 혁신



핵심 메시지

N²SF는 데이터/업무를 C·S·O로 분류하고, 등급에 따라 통제를 차등 적용합니다. 개인정보는 정보공개 원칙상 S에서 시작합니다.

개인정보는 어느 등급인가?

N²SF의 C/S/O 등급 체계에서 개인정보 범주별 권장 등급과 고려사항

🛡️ N2SF 등급 매트릭스

ℹ️ 정보 등급은 위험평가에 따라 기관별 조정 가능

개인정보 범주	사례	권장 기본 등급	상향(C) 고려 케이스
일반 개인정보	성명, 연락처, 이메일, 주소 등	S(민감)	대량 보유/특정 직무군 신상/ 표적화 위험 높음
민감정보	건강, 사상, 생체, 범죄경력 등	S(최소)	의료·치안 원장 등 중대 피해 우려
고유식별정보	여권, 운전면허, 외국인등록번호	S(강화)	원장/레지스트리· 대량 일괄 저장·인증키 용도
주민등록번호	-	S(강화) C 권고	기관 원장/연계 허브/ 대규모 백업·DR
공개 가능한 데이터	공공데이터, 공자·보도자료 등	O(공개)	-

⚠️ 법에 고정 매핑은 없음 - 위험평가와 업무 중요도에 따라 상향 여부 결정

⬆️ 주민등록번호/고유·민감정보는 추가 보호 요구가 커서 핵심 저장소·백업 구간은 C 상향을 적극 검토

N²SF와 AI 도입의 새로운 기회

디지털 혁신을 위한 새로운 가능성

기회 요소

-  경직된 망분리 규제 완화
물리적 망분리에서 벗어나 유연한 보안 체계로 전환
-  클라우드·AI 접근성 향상
외부 연결 기술을 활용한 생산성 향상
-  대민 서비스 혁신
챗봇, 자동응답 등 AI 기반 맞춤형 서비스 제공
-  업무 효율성 증대
반복 업무 자동화 및 데이터 기반 의사결정 지원

※ 2025년 9월 국가망 보안 체계 정식 가이드라인 1.0 발표 예정

AI 도입 시 핵심 과제

개인정보보호와 혁신의 균형점 찾기

해결 과제

-  위험평가 체계 구축
데이터 중요도별 차등 보안통제, 사전 위험분석 도입
-  증적관리 강화
개인정보 처리 전 과정의 추적성 및 책임소재 명확화
-  개인정보 최소화
필요 최소한의 정보만 수집·이용하는 체계 마련
-  보안과 혁신의 균형
개인정보 보호와 업무 효율성의 균형점 모색

※ 공공기관 국가망 보안 체계 환경에서 AI 도입 준비 필수

개인정보보호 정책동향

인공지능 개발·활용 과정 개인정보 보호 노력

2025년 8월

생성형 인공지능(AI) 개발·활용을 위한 개인정보 처리 안내서

생성형 AI 데이터 수집, 학습, 활용 단계별 개인정보 처리 기준 종합
제시



2024년 12월

국민이 신뢰할 수 있는 인공지능 시대를 위한 AI 프라이버시
리스크 관리 모델 제시

기업이 자율적으로 프라이버시 리스크를 관리할 수 있도록 AI
생애주기에 걸친 프라이버시 리스크 관리의 방향과 원칙, 리스크 유형,
경감방안 제시



2025년 7월

인터넷망 차단조치 규제 개선

인공지능·클라우드 등 신기술 환경에 맞는 유연하고 차등적인 보안
규제 전환



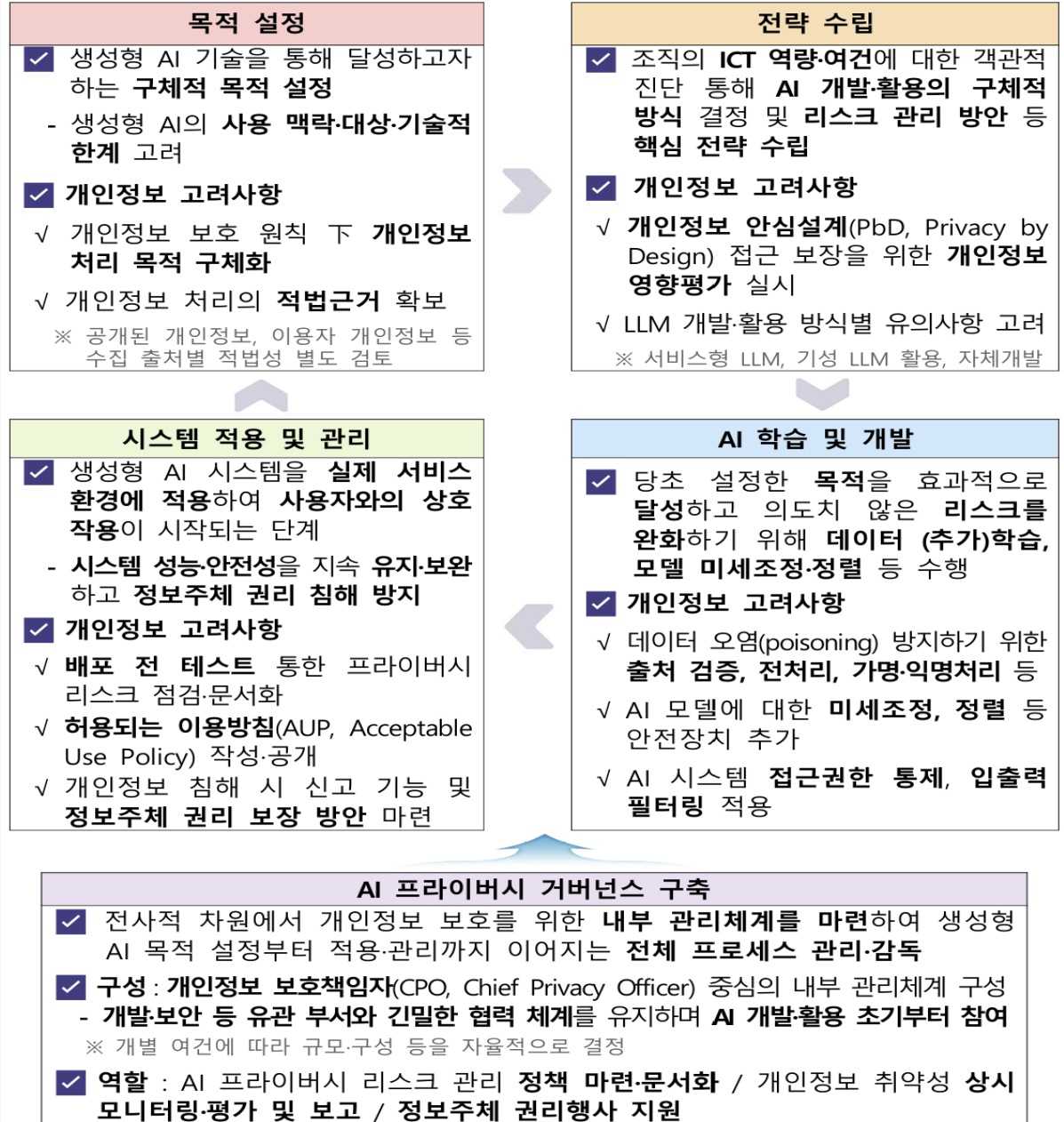
2024년 7월

인공지능 개발·서비스에 이용되는 '공개 데이터' 처리 기준

공개된 개인정보 수집·활용의 법적기준을 명확화하고 인공지능 개발 및
서비스 단계에서 참고할 수 있는 최소한의 기준 제시

생성형 인공지능(AI) 개발·활용을 위한 개인정보 처리 안내서

생성형AI수명주기 각 단계에서 고려해야할
개인정보처리 및 보호이슈를 체계화 하고,
그에 따른 법적기준 및 안전조치 등을 제시

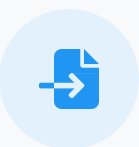
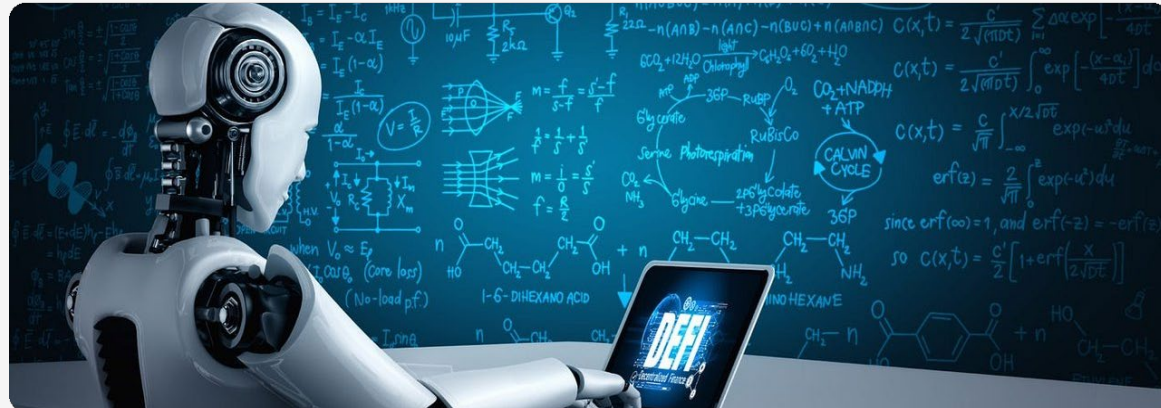


개인정보 생애주기 전체 구조

AI 시스템 개인정보 생애주기 5단계별 핵심 체크포인트

 엑셀 양식 제공

 개인정보보호위원회「AI 프라이버시 리스크 관리 모델」참고



1

수집

Collection

적법한 개인정보 확보·최소화

- ✓ 목적제한·최소수집
- ✓ 법적 근거 확보
- ✓ PIA 영향평가



2

저장

Storage

등급분리·접근통제 강화

- ✓ 등급별 저장소 분리
- ✓ 접근권한 최소화
- ✓ 인덱스 가명화



3

이용

Usage

AI 출력물 통제·권리 보장

- ✓ 후처리 필터링
- ✓ 설명요구권 보장
- ✓ 로그 기록 유지



4

제공

Provision

전송 보안·추적성 확보

- ✓ 전송 경로 암호화
- ✓ 국외이전 통제
- ✓ 제공 이력 관리



5

파기

Destruction

완전 파기·증빙 확보

- ✓ 신속 파기
- ✓ 자동화 파이프라인
- ✓ 삭제 증빙 보관

1

개인정보 수집 단계 체크포인트

목적제한·전처리·PIA 검토

수집 단계는 개인정보의 적법한 수집과
최소수집이 핵심입니다. 법적 근거와 목적을
명확히 설정해야 합니다.

참고: 개인정보보호법 제15조, 제16조

◎ 목적제한 · 최소수집

명확한 목적 특정 및 최소한의 정보만 수집,
법적 근거 확정 후 처리방침 일치 필요

▼ 프롬프트 전처리

개인정보 포함 가능성 높은 데이터는 식별정보
유입 차단

☞ PIA 검토

개인정보보호법 제33조에 따라 영향평가 대상
여부 판단. 해당 시 필수 이행

⌘ 추가 목적 활용

목적 외 AI 학습 활용 시 관련성·안전조치 기준
으로 적법성 판단

2

개인정보 저장 단계 체크포인트

등급분리·권한 최소화를 통한 데이터 보안

저장 단계의 핵심은 등급분리와 권한 최소화입니다.
데이터의 중요도에 따른 C/S/O 등급별 저장소를
분리하여 C/S/O 간 직접 전송을 금지하고, 예외 시
사전 승인·레덱션·DLP 증적을 보관해야 합니다.

≡ C/S/O 등급별 저장소 분리 운영

⊘ C/S/O 간 직접 전송 금지 원칙

🛡️ Zero Trust 기반 접근권한 최소화

👤 다중인증(MFA) 의무 적용

참고: 개인정보보호위원회 AI 개인정보보호 자율점검표

N²SF 데이터 보안 계층 구조

C

Confidential (기밀) 데이터

개인식별이 가능한 고유식별정보, 민감정보 등 최고 수준의 보안
이 필요한 데이터

✓ 강화된 암호화 및 접근통제

S

Sensitive (민감) 데이터

부분적으로 가명처리된 데이터 또는 결합 시 개인식별 가능성
이 있는 데이터

✓ 표준 암호화 적용

O

Open (공개) 데이터

완전히 비식별화된 데이터 또는 공개 가능한 일반 정보

✓ 기본 보안 조치 적용

3

개인정보 이용 단계 체크포인트

후처리·자동화된 결정 권리보장·로그 및 감사

개인정보 활용 과정에서 정보주체의 권리를 보장하고 데이터 안전성을 확보하기 위한 관리적 기술적 조치를 수행해야 합니다.

참고: 개인정보보호위원회 AI 개인정보보호 자율점검표

㉔ 출력 후처리 및 데이터 보호

생성형 AI의 응답에 개인정보가 포함되는 것을 방지하기 위한 기술적 조치 적용

- ▼ 출력 필터링
- ∞ 마스킹
- ⊖ 결과 차단
- ≡ 워터마크
- 📄 복사제한
- 🔒 일회성토큰

▼ 자동화된 결정에 대한 권리 보장

정보주체의 권리에 중대한 영향을 미칠 수 있는 결정을 자동으로 수행하는 경우, 법적 권리 보장

- 👤 거부권고지및행사절차
- 🔗 인간개입보장
- 🔍 설명요구권보장
- 👤 이의제기프로세스

㉔ 성능과 보안의 균형

개인정보 보호 조치로 인한 성능 저하를 최소화하는 전략적 접근

- 🔍 경량 필터 우선 적용
- 📊 성능 모니터링
- 🚨 고위험 상황에 고급 필터링

㉔ 로그 기록 및 감사

개인정보 이용 과정의 모든 활동 기록 및 주기적인 감사로 비정상적인 이용 패턴 식별

- 📖 상세 로그 기록
- 🔍 이상 패턴 탐지
- 📅 정기 감사 실시
- 📄 감사 보고서 작성

① 국가 망 보안 체계 환경: 입력 데이터 C/S/O 등급 분류가 보안 통제 수준 결정

4

개인정보 제공 단계 체크포인트

안전한 데이터 전송 원칙

공공기관 AI 도입 시 개인정보 외부 제공 과정에서는 엄격한 데이터 전송 보안이 필수적입니다.
N2SF 환경에서는 데이터 등급별 차등화된 보안 통제가 적용되어야 합니다.



전송 보안 및 암호화

- ✓ mTLS와 DLP/CASB 솔루션으로 전송 경로 보호 및
- ✓ 데이터 유출 방지 TLS 1.3 이상 필수 적용



인터페이스 최소화

- ✓ API 인터페이스를 필요 최소 범위로 제한
- ✓ 개인정보 관련 엔드포인트에 추가 인증 적용
- ✓ 접근 제어와 권한 분리로 정보 접근 최소화



국외 이전 통제

- ✓ 외부 API·해외 서비스 이용 시 계약 필수 포함 항목
- ✓ 국외 이전 통제 · Data Residency · No store



제공 이력 관리

- ✓ 개인정보 제공 시 법적 근거 명확화(제공·위탁·서브프로세서) 변경 등 모든 이력 관리
- ✓ 추적 가능성 확보

5

개인정보 파기 단계 체크포인트

신속한 파기·연쇄 삭제 자동화·정보주체 요청 대응

개인정보 생애주기 종료 시 안전한 파기와
개인정보 저장 지점이 여러 계층으로 나뉘므로
연쇄 삭제 파이프라인을 통해 자동화되도록
설계하는 것이 중요합니다.

복구가 필요한 경우에도 복구 후 동일한 삭제
정책이 재적용되도록 절차 마련하고, 삭제 기록의
증빙과 무결성 로그를 함께 보관해야 합니다.

참고: 개인정보보호법 제21조 및 시행령 제16조

신속한 파기

보존기간 종료 즉시 개인정보 파기, 자동화된
파이프라인으로 누락 방지

 즉시파기

 자동파이프라인

 누락방지

연쇄 삭제 자동화

여러 저장 계층(RAG, 벡터DB, 원문DB)에서
연쇄적 삭제 자동화 구현

 RAG인덱스

 벡터DB

 원문DB

삭제 증빙 확보

삭제 증빙 로그 확보, 복구 후에도 동일 삭제 정
책 재적용

 삭제로그

 무결성보장

 증빙자료보관

정보주체 요청 대응

삭제 요청 처리 절차 명확화, 외부 서비스도
삭제 이행 검증

 처리절차

 외부서비스검증

 결과통지

AI 구축 유형별 메트릭스

AI 도입 형태에 따른 위험구조와 개인정보보호 방안이 다릅니다.
각 유형별 특성을 이해하고 적절한 개인정보 보호 체계를 구축하는 것이 중요합니다.

자체구축형

내부 데이터베이스연계시 **입력·모델보안** 중요

특징

- ✓ 내부 통제 **용이**, 데이터 흐름 관리 가능
- ✓ 높은 초기 구축 비용, 전문 인력 필요

개인정보보호 방안

- > 입력데이터 **전처리 필터링** 적용
- > 출력 검증 및 후처리 시스템 구축
- > 모델보안 및 권한관리 강화

 **권장 - 위험 관리 용이**

외부 API 구축형

데이터 **외부 전송** 순간 통제 한계 발생

특징

- ✓ 구축 비용 절감, 빠른 도입 가능 데이터
- ✓ 전송 시점 이후 **통제 제한적**

개인정보보호 방안

- > **암호화** 및 전송 데이터 최소화 전송
- > 로그 관리 및 감사 체계 마련 계약시
- > **개인정보 처리 조항** 명시

 **조건부 권장 - 적절한 통제 필요**

해외 서비스형

국외이전 이슈 및 외국 법제 적용 가능성

특징

- ✓ 최신 AI 기술 즉시 활용 가능 **국외이전**
- ✓ **Data Residency** 이슈

개인정보보호 방안

- > **가명처리** 및 익명화 전처리 필수
- > 국외이전 고지, 파기권, Opt-out 명시
- > 사고 발생 책임 소재 명확화

 **제한적 검토 - 엄격한 조건 필요**

AI 구축 유형별 고려사항 비교

AI 도입 형태에 따른 위험구조와 개인정보보호 방안이 다릅니다.
각 유형별 특성을 이해하고 적절한 개인정보 보호 체계를 구축하는 것이 중요합니다.

구분	자체 구축형	외부 API형	해외 서비스형
위험구조	내부 데이터베이스 연계 시 입력·후처리 중요	데이터 외부 전송 순간 통제 한계 발생	데이터 국외이전 이슈 및 외국 법제 적용 가능성
통제 가능성	높음 - 내부 통제 비교적 용이	중간 - 전송 보안 및 데이터 최소화로 보완	낮음 - 계약 및 기술적 조치로 부분 보완
핵심 조치	입력 전처리, 출력 검증, 내부 보안 통제	암호화, 전송 최소화, 로그 관리, 개인 정보 차단	가명처리, DPA/SCC 계약, 국외이전 고지
사례	국민신문고 AI 민원 응답 시스템	서울시여성가족재단 DARVIS 챗봇	공공기관 공식 도입 사례 없음 (DeepSeek 차단 사례)
권장 수준	권장 - 위험 관리 용이	조건부 권장 - 적절한 통제 필요	제한적 검토 - 엄격한 조건 하에 고려

1

자체 구축형 AI 도입 체크포인트

신속한 파기·연쇄 삭제 자동화·정보주체 요청 대응

내부 AI 시스템은 데이터와 모델에 대한 직접 통제가 가능하지만, 철저한 보안체계가 필수적입니다.

 국민신문고 AI, 행안부 챗봇, 특허청 AI 심사 시스템 사례

데이터 안전한 관리

내부 데이터베이스 연동 시 안전한 파이프라인을 구축하고 철저한 접근 통제 필요

 익명화 파이프라인

 온프레미스 환경 접근 통제

입력 필터링

여러 저장 계층(RAG, 벡터DB, 원문DB)에서 연쇄적 삭제 자동화 구현

 개인식별정보 자동 탐지

 민감정보 차단

모델 보안 강화

AI 모델의 보안을 강화하고 학습 데이터 유출 방지하기 위한 보안 적용

 프롬프트 인젝션 방어

 모델 추론 방지

접근 권한 관리 및 감사

AI 시스템과 학습 데이터에 대한 접근 권한 통제 및 데이터 사용의 투명성 확보

 최소권한 원칙

 이상 패턴 탐지

2

외부 API 구축형 체크포인트

전송 보안·법적 API 관리·벤더 종속

데이터 전송 과정에서의 발생 가능한 개인정보 유출과 API 서비스 제공자와의 법적 조항이 주요 이슈입니다.

또한, 벤더 종속 및 출구 전략을 수립하여 데이터 이전 및 대체 서비스 전환 계획을 마련해야 합니다.

 서울시여성가족재단 AI 챗봇 사례

데이터 암호화 및 전송 보안

외부 API와 통신 과정에서 개인정보 보호를 위한 강력한 암호화 방식 적용

 TLS13+암호화

 최소화전송원칙

 가명처리

 마스킹

 토큰화

API 키 및 로그 관리

API 호출 전 과정을 추적하고 이상 패턴 자동 감지 로깅 체계 구축

 상세요청/응답로깅

 이상패턴자동탐지

 90일주기키순환

 다중인증(MFA)

법적 보호장치

API 서비스 제공자와의 계약에 개인정보보호를 위한 필수 법적 조항을 포함해야 합니다.

 즉시삭제조항

 제3자제공금지

 국외이전제한

 비밀유지의무

벤더 종속 및 출구 전략

외부 API 서비스 중단에 대비한 데이터 이전 및 대체 서비스 전환 계획을 수립해야 합니다.

 데이터이식성확보

 SLA명확화

 백업API연계

 표준프로토콜고수

3

해외 서비스형 체크포인트

국외 이전 관리·책임 및 위험관리

데이터 통제 불가능성과 개인정보 국외 이전 리스크를 고려해야 합니다.

입력 데이터의 저장 위치와 보존 기간, 모델 학습 등 2차 활용 여부를 명확히 해야 합니다.

또한, 국내외 관련 법률 모두의 준수를 기본 원칙으로 필요한 법적·기술적 보호조치를 설계해야 합니다.

 Deepseek 사례

🌐 국외 데이터 이전 관리

해외 서비스로 개인정보 이전 시
정보주체에게 이전 사실을 고지하고 동의를

✔️ 이전국가명시

✔️ 사전동의

✔️ 기간안내

✔️ 정보주체권리보장

📁 데이터 최소화

해외 서비스에 전송하는 개인정보는 필요
최소한으로 제한하고 사전 비식별 조치 수행

∞ 가명처리/마스크

✂ 불필요 정보 제거

⚡ 최소화데이터전송

🔍 익명화검토

📄 계약 보호장치

해외 서비스 제공자와 개인정보 보호를 위한
법적 구속력 있는 계약 체결

📄 DPA계약체결

📄 SCC 문서화

📄 서비스종료시즉시삭제

🔍 감사원한확보

🔑 책임 및 위험관리

국내법 준수와 위반 시 책임소재를 명확히
하고 위험 발생 시 대응 방안 마련

👤 국내대리인지정

📄 피해배상프로세스

⚠ 사고대응체계

🛡 보험가입검토

국민신문고 AI 민원응답 시스템

인공지능 기반 민원 서비스 혁신 사례

☰ 도입 배경 및 개요

국민권익위는 민원 처리 효율성 향상을 위해 생성형 AI 기반 민원 응답 시스템을 도입, 공무원의 민원 답변 초안을 자동 생성합니다.

"AI가 민원 요지를 추출하고 처리자 정보를 포함한 답변 초안 자동 생성"

- 국민권익위원회, 2025년 6월 보도자료

🛡️ 개인정보보호 핵심 조치

▼ 데이터 비식별화 및 최소 수집

학습 및 처리 단계에서 불필요한 개인정보는 모두 삭제·마스킹하고, 반드시 필요한 정보만을 가명·익명화하여 사용합니다.

✓ 생성된 답변 검증

AI 생성 답변의 개인정보 포함 여부 이중 검증. 자동 필터링 후 담당자 최종 확인 필수

☰ 내부 전용 서버 운용

AI 모델과 민원 데이터는 외부 네트워크와 분리된 내부망에서만 운영하여, 개인정보 유출 위험을 최소화

🕒 개인정보 영향평가 및 정기감사

신규 기능이나 대규모 데이터 변경 시 사전적으로 개인정보 영향평가를 실시하고, 운영 중에는 내·외부 보안 감사를 실시

서울시 여성가족재단 AI 챗봇

i 도입 배경

☞ 행정 효율화
인력 부족 문제 해결 및 업무 자동화

👤 민감정보 처리
성범죄 예방·상담 등 민감 분야 신속 대응

i 주요 목표

🛡️ 정보보호 강화
민감정보 유출 방지 체계 구축

☞ 상담 품질 향상
상담사 핵심업무 집중 환경 조성

🛡️ 개인정보보호 핵심 조치

▼ 개인정보 암호화 및 안전한 전송

챗봇과 API 서버 간 개인정보가 오갈 때 항상 암호화된 채널(HTTPS 등)을 사용해 외부 유출 위험 감소

☑ 위·수탁 및 외부 API 업체 관리

개인정보처리 위탁 계약에 보호조치 명확히 규정, 제3자 제공 금지 등의 위촉 사항을 엄격하게 관리

👁 데이터 최소화 및 자동 파기

챗봇 대화에서 불필요한 개인정보 수집을 배제하고, 일정 기간 후 자동 삭제·파기 절차를 운영

📄 옵트 아웃 명시

챗봇이나 API 서비스에 입력한 데이터가 추후 AI 모델 학습 데이터로 활용되는 2차 피해발생 방지

💡 핵심 시사점: 데이터가 외부로 전송되는 과정과 옵트 아웃이 핵심

DeepSeek 접속 제한 사례

데이터 통제와 개인정보 국외 이전 리스크 관리

Ⓞ 일부 공공·기업 네트워크에서 해외 생성형 AI 서비스 접속 제한 조치 시행

⚠ 핵심 리스크 요인

☰ 데이터 통제 불가능성
입력 데이터의 저장 위치, 보존 기간, 모델 학습 등 2차 활용 여부 확인·통제 어려움

👤 권리 보장 실효성 문제
열람·삭제 등 정보주체 권리 보장의 실효성 불투명

🔑 법적 접근 요구 위험
일부 관할에서 정부 또는 사법기관의 데이터 접근 요구 가능성

※ 위험은 특정 국가의 서비스로 한정되지 않음

🌐 글로벌 AI 기업의 구조적 한계

⚙ 표준화된 플랫폼

OpenAI, Google, Microsoft 등 글로벌 AI 기업은 전 세계 고객을 대상으로 표준화된 플랫폼 운영

🔄 전략 전환

사업자에게 맞춤 반응을 기대하기보다 기관 내부에서 스스로 통제·증적 체계를 갖추는 전략 필요

🛡 국외 AI 활용 실행 원칙

∞ 원칙 1: 법령 준수 및 다국적 규제 대응

국내외 개인정보보호법, GDPR 등 국제법과 현지 법률을 모두 준수하며, 특히 국외 이전 및 저장에 관한 법적 요구사항을 철저히 이행

⚡ 원칙 2: 비식별화 및 가명처리 기술 적용

비식별화 또는 가명처리를 실시하여 개인정보 노출 위험을 최소화하는 기술적 조치 필수

📄 원칙 3: 법적 보호장치 마련

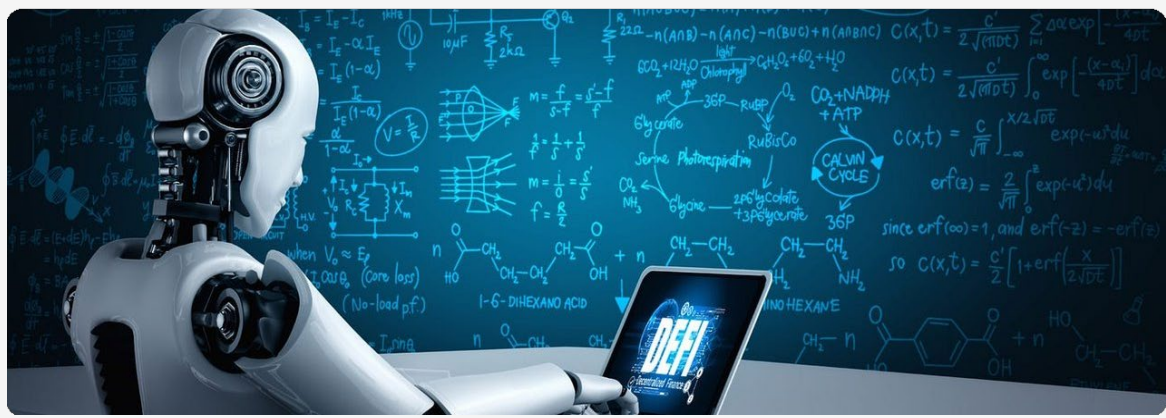
DPA 및 SCC 계약으로 국외 이전·삭제 절차·옵트 아웃·서브프로세서 고지 등 명문화

※ 정량적 위험 진단을 통한 제한적 활용 검토가 최선의 접근

실무 가이드라인: 3가지 핵심영역

공공기관 AI 도입 시 필수 개인정보보호 영역과 핵심 영역

- ☞ 「인공지능(AI) 개발·서비스를 위한 공개된 개인정보 처리 안내서」
- ☞ 개인정보보호 자율점검표 참고



법적 준수

규제 이해 및 이행

법적 위험 사전 방지를 위한 필수 준수사항

- ✓ 정당한 이익 요건 충족
- ✓ 개인정보 영향평가 실시
- ✓ 처리근거 명확화·문서화



기술적·관리적 조치

데이터 보안 및 모니터링

AI 시스템 전 과정의 개인정보보호

- ✓ 가명·익명화 처리
- ✓ 데이터 필터링 강화
- ✓ 침해테스트 정기 실시



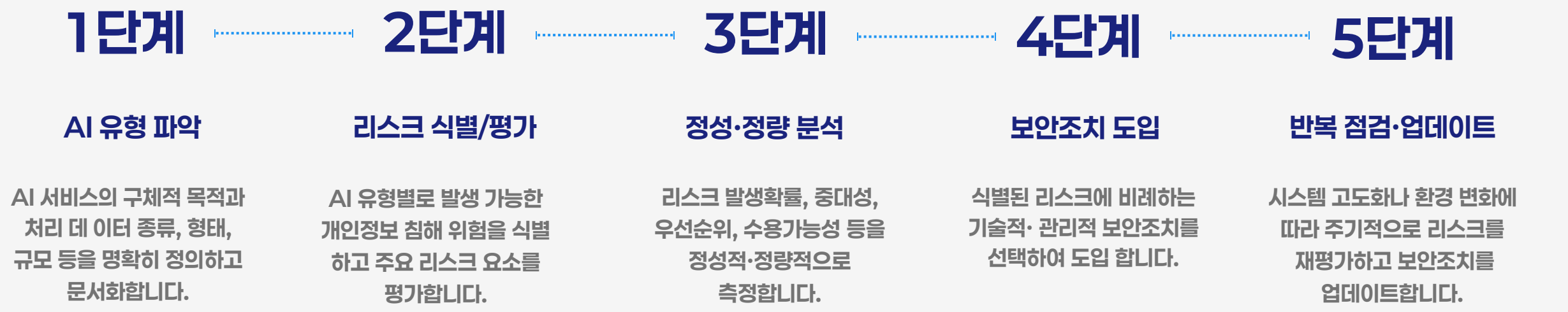
투명성·설명책임

국민 신뢰 확보

처리과정 설명과 정보주체 통제권 보장

- ✓ AI 의사결정 설명 체계
- ✓ 권리행사 절차 간소화
- ✓ 위험상황 신속대응 체계

AI 프라이버시 리스크 관리 절차



개인정보 보호 중심 설계(PbD) 관점에서 AI 모델·시스템의 기획·개발 단계부터 개인정보보호책임자(CPO) 주도로 관리

체크리스트 실무 활용법

개인정보보호 체크리스트 활용 및 관리체계 연동 방안
발표 자료 배포 안내 | 강연 소개 페이지에서 다운로드 가능



AI 개인정보보호 체크리스트.xlsx

강연 소개 페이지에서 다운로드 가능

☞ 체크리스트 구성

AI 도입 시 개인정보 생애주기별 고려사항, 구축 유형별 고려사항이 각각의 시트로 구성되어 효율적인 점검 가능



법률 및 표준 연동

개인정보보호법과 ISMS-P 기준에 연동되도록 설계되어 법적 요구사항과 표준 준수 여부를 동시에 확인 가능



자체 점검 활용

연 1회 이상 수행해야 하는 자체 점검의 기초 자료로 활용 겸 활용하여 체계적인 관리체계 운영 지원



인증심사 대비

ISMS-P 인증 심사 시 AI 영역 점검 항목에 대한 도구로 활용 가능



맞춤 수정 가능

귀 기관의 업무환경에 맞춰 자유롭게 수정·보완하여 활용 가능한 오픈 포맷으로 제공



증적관리 지원

각 항목별 이행 여부, 담당자, 증적 자료 관리 기능 포함으로 체계적인 개인정보보호 관리 가능

AI 개인정보 체크리스트 요약

AI Implementation Checklist Summary

AI 시스템 도입 시 유형별 개인정보보호 점검사항 종합

전체 86개 항목

필수 70개

권장 16개

개인정보 생애주기 29개 항목

- ✓ 처리 목적·적법근거 명확화 **필수**
- ✓ PII 필터링(탐지→마스킹/차단) **필수**
- ✓ Zero Trust 접근권한 최소화 **필수**
- ✓ RAG 인덱스 익명화 **필수**
- ✓ 안전한 데이터 전송 보안 **필수**

자체구축형 AI 15개 항목

- ✓ N2SF 기준선·C/S/O 등급 분리 **필수**
- ✓ PIA 대상성 검토 및 수행 **필수**
- ✓ 학습·추론 데이터 카탈로그 **권장**
- ✓ 모델 파라미터 암호화 **필수**
- ✓ 접근권한 최소화 원칙 **필수**

외부 API형 AI 13개 항목

- ✓ DPA 체결(보관/학습 금지) **필수**
- ✓ 벤더 콘솔 강제 설정 **필수**
- ✓ 전송 암호화(TLS 1.3+) **필수**
- ✓ 토큰 기반 인증 **필수**
- ✓ API 호출 로그 수집 **권장**

해외 AI 서비스 29개 항목

- ✓ 지정 지역 내 데이터 저장·처리 **필수**
- ✓ 국외 이전 법적 근거 확보 **필수**
- ✓ 개인정보 최소화·비식별화 **필수**
- ✓ 서버프로세서 관리 **권장**
- ✓ 정기 보안 감사 **권장**

체크리스트 통계 4개 영역

- 🔄 개인정보 생애주기 (5단계)
- ✓ 개인정보 생애주기 **29개**
- ✓ 수집: 6개 / 저장: 6개 / 이용: 7개
- ✓ 제공: 5개 / 파기: 5개
- 📄 도입 유형별 체크리스트 (3유형)
- ✓ 자체구축형 AI **15개**
- ✓ 공통코어: 2개 / 거버넌스: 3개
- ✓ DevSecOps: 3개 / 기타: 7개
- ✓ 외부 API형 AI **13개**
- ✓ 공통코어: 3개 / 전송/게이트웨이: 2개
- ✓ 데이터 통제: 2개 / 기타: 6개
- ✓ 해외 AI 서비스 **29개**
- ✓ 데이터: 6개 / 최소화·비식별: 4개
- ✓ API 게이트웨이·전송: 3개 / 기타: 16개

개인정보 생애주기 체크리스트 (5단계)

Personal Information Lifecycle Checklist

AI 시스템 도입 시 생애주기 단계별 개인정보보호 점검사항

전체 29개 항목

필수 25개

권장 4개

수집 단계

6개 항목

✓ 처리 목적·적법근거 명확화

필수

✓ 추가적 이용 기준 내재화·공개

필수

✓ 입력단 PII 필터링, 로그 최소화

필수

✓ 민감정보 입력 경고/가이드

필수

✓ 정보주체 권리 공지 및 이행방법

필수

✓ 자동수집장치 고지 및 동의

필수

저장 단계

6개 항목

✓ C/S/O 등급별 저장소 분리

필수

✓ 데이터 암호화 및 백업 정책

필수

✓ 학습데이터 카탈로그/인벤토리

필수

✓ ML 벡터/임베딩 익명화 조치

필수

✓ 파라미터 접근통제 및 변경감지

필수

✓ 데이터 보관기간 설정

권장

이용 단계

7개 항목

✓ 권한 최소화 및 접근통제

필수

✓ 프롬프트 인젝션 방지 필터

필수

✓ 개인정보 추출/재구성 방지

필수

✓ RAG 인덱스 익명화 및 통제

필수

✓ 적절한 로깅 및 경고체계

필수

✓ 모델 정확성 및 편향성 점검

권장

✓ 접근 이력 관리 및 모니터링

필수

제공 단계

5개 항목

✓ 안전한 전송 프로토콜 적용

필수

✓ 제3자 제공 시 동의 확인

필수

✓ API 보안 및 토큰 인증

필수

✓ 국외이전 시 법적 요건 충족

필수

✓ 개인정보 전송요구권 이행

권장

파기 단계

5개 항목

✓ 보존기간 경과 시 자동 파기

필수

✓ 파기 이력 관리 및 증적 보관

필수

✓ 학습데이터/모델 파기절차

필수

✓ 철회권 행사 시 파기 프로세스

필수

✓ 백업/캐시 데이터 완전 삭제

권장

※ 개인정보 생애주기 단계별 체크리스트는 공공기관 N2SF 환경에서 AI 시스템 도입 시 필수적인 개인정보보호 조치사항입니다.

32

자체구축형 AI 체크리스트

N2SF 환경에 맞춘 보안 체계 적용 및 개인정보 보호 방안

전체 15개항목

필수 12개

권장 3개

기반 구조 및 거버넌스 7개 항목

공통코어

- ✓ N2SF 기준선·C/S/O 등급 분리 필수
- ✓ PIA 대상성 검토 및 수행(대상 시) 필수

거버넌스

- ✓ 학습·추론 데이터 카탈로그/데이터맵(원본·가명·레덱션·인덱스) 필수
- ✓ 자동화 PII 탐지·마스킹 통합 파이프라인 구축 필수
- ✓ 대량 데이터셋 삭제·모델 재학습 자동화 체계 권장

개발 및 네트워크 보안 5개 항목

DevSecOps

- ✓ 소스코드·모델 파라미터 저장 보안 필수
- ✓ 개발·테스트·운영 환경 분리(접근권한 차등) 필수
- ✓ AI 출력 결과물의 PII 필터링·마스킹 후처리 필수

네트워크/전송

- ✓ API 게이트웨이·전송 구간 암호화(TLS 1.3+) 필수

로깅/감사

- ✓ AI 로그·감사증적 수집·관리 필수

권리보장 및 파기/백업 5개 항목

권리이행

- ✓ 정보주체 권리행사 처리 자동화 필수

백업/DR/파기

- ✓ 백업·DR 정책(암호화·접근제어·위치고정) 필수
- ✓ 데이터·학습모델 파기절차·이중확인(완전삭제) 권장

특례

- ✓ 프로파일링·자동화 의사결정 대응(설명·이의제기권) 필수
- ✓ 가명정보 추가 안전조치(결합방지·재식별 금지) 권장

※ N2SF 등급(C/S/O)에 따라 필수 항목의 기준선이 달라질 수 있습니다. 특히 S 등급 이상 시스템에서는 모든 항목이 필수 적용 대상입니다.

외부 API형 AI 체크리스트

제3자 AI API 활용(챗GPT API, 클로바X API 등)

전체 13개항목

필수 12개

권장 1개



공통코어

3개 항목

- ✓ DPA 체결(보관/학습 금지, 지역 고정 등) 필수
- ✓ PIA 대상성 검토 및 수행(대상 시) 필수
- ✓ 벤더 설정(보관 금지·학습 금지/리전 고정) 필수



전송/게이트웨이

2개 항목

- ✓ 전송 암호화(TLS 1.3+ 강제, 인증서 검증) 필수
- ✓ PII 필터링 게이트웨이 구축 필수



데이터 통제

2개 항목

- ✓ API 인증 강화(토큰 기반/키 순환/IP 제한) 필수
- ✓ 응답 후처리 필터링 필수



벤더 보증/감사

2개 항목

- ✓ 로그 수집·감사 필수
- ✓ 벤더 보증 확인 권장 권장



권리·파기

2개 항목

- ✓ 권리 이행 프로세스 필수
- ✓ 파기 이행·증적 필수



특례

2개 항목

- ✓ 가명·익명 정보 특례 요건 검토 필수
- ✓ 과학적 연구 목적 처리시 안전조치 필수

해외 AI 서비스 체크리스트

국외 데이터 이전에 따른 관리·통제 점검항목
글로벌 AI 서비스 활용 시 안전조치 체크포인트

전체 29개항목

필수 21개

권장 8개

데이터 지역 통제4개 항목

✓

고객 콘텐츠를 지정 지역 내에서만 저장·처리

필수

✓

로그/메타데이터도 동일 지역으로 고정

필수

✓

백업/DR/캐시 데이터 지역 통제

필수

✓

리전간 데이터 이동 로그·모니터링

필수

최소화·비식별화4개 항목

✓

고객 데이터 최소화 기술 적용

필수

✓

목적 달성 후 즉시 데이터 삭제

필수

✓

마스킹/토큰화/익명화 기법 적용

권장

✓

데이터 최소화 정책 문서화

권장

API 게이트웨이·전송3개 항목

✓

전송 암호화(TLS 1.3+) 강제화

필수

✓

PII 필터 및 마스킹 게이트웨이

필수

✓

전송 로그 자동 수집·보관

필수

국외이전·계약3개 항목

✓

해외 이전 법적 근거 확보

필수

✓

DPA 체결 및 책임 조항 명시

필수

✓

보관/학습 금지 규정 적용

필수

서브프로세서 관리4개 항목

✓

서브프로세서 목록 사전 공개

필수

✓

변경 시 사전 통지 및 거부권

필수

서브프로세서 관리(계속)

✓

동일 수준 계약 의무 전파

필수

✓

서브프로세서 보안 평가

권장

보존·삭제·권리4개 항목

✓

데이터 보유기간 명확화

필수

✓

목적 달성 시 완전 삭제

필수

✓

권리행사 이행 프로세스

필수

✓

삭제 증명 획득 및 보관

권장

보안 통제·감사7개 항목

✓

권한 통제 및 최소화 원칙

필수

✓

인증 관리 및 정기 검토

필수

※ 해외 서비스의 경우 국내 개인정보 보호법과 현지 법령(GDPR 등)의 교차 준수가 필요합니다

AI

결론 및 실행 방안

AI 도입은 단순한 기술혁신이 아니라,
개인정보 보호 역량의 확장을 동시에 요구 합니다

01

체크리스트 실무 적용 및
담당자 지정

02

주기적 점검 및 개인정보
영향평가 실시

03

법령 변화 모니터링 및
지속적 업데이트

04

국민 신뢰 확보를 위한
투명한 정보 공개

INPUT



0000000000000000



MASKING

DATA



PII



BIOMETRICS



LOCATION



CIO/MINAL



STORE

LEAK
PATHS

TRAIN

UNKNOWN
SERVERS



DPA

NO-STORE



>>>



OP-OUT



OPT-OUT



체크리스트 다운로드 QR링크

오늘 발표 자료가 귀 기관의 개인정보보호체계 강화에
실질적인 도움이 되기를 희망합니다.

✉ E-mail : bwmslove@naver.com

✉ 기관 특성에 맞게 수정·보완 활용 가능